

Matriz de Evaluación PRAGMATIC Completa para indicadores FAIR-STRIDE

Nota: se propone una escala 0-5 para cada criterio PRAGMATIC (0 = nulo, 5 = excelente). Las puntuaciones son orientativas y deben revisarse en cada contexto.

1. Autenticidad

Indicador A1 – N° de incidentes de suplantación de identidad en sistemas críticos (anual)

Criterio	Score	Comentario breve
Predictivo	3	Describe el pasado; su tendencia ayuda a anticipar, pero no capta riesgo latente
Relevante	5	Directamente ligado a fraudes y accesos no autorizados
Accionable	4	Orienta refuerzo de controles y campañas de concienciación
Genuino	4	Mide incidentes reales; depende de calidad de detección y registro
Significativo	4	Cambios en el indicador suelen ser interpretables
Preciso	3	Posibles sub-registros; mejora con taxonomía común
Oportuno	4	Puede medirse mensual/trimestral
Independiente	3	Puede infra-reportarse si se asocia a penalizaciones internas
Rentable	4	Se apoya en registros de incidentes ya existentes

Indicador A2 – Pérdida anual esperada por suplantación (FAIR, media y p90, en euros)

Criterio	Score	Comentario breve
Predictivo	5	Modela riesgo futuro (distribuciones de pérdidas)
Relevante	5	Directamente interpretable por negocio y reguladores
Accionable	5	Permite priorizar inversiones y seguros
Genuino	4	Depende de calidad de supuestos y datos FAIR
Significativo	5	Cambios son claros en impacto económico
Preciso	3	Rango de incertidumbre; suficiente si se documenta
Oportuno	3	No se actualiza diariamente; suele ser anual/semestral
Independiente	4	Difícil de manipular sin dejar rastro (supuestos FAIR)
Rentable	3	Requiere esfuerzo analítico, pero justificable para riesgos materiales

Indicador A3 – % de transacciones críticas protegidas por MFA/FIDO2

Criterio	Score	Comentario breve
Predictivo	4	Mayor % suele correlacionar con menor exposición a suplantación
Relevante	4	Directamente vinculado a controles de autenticación
Accionable	5	Indica dónde priorizar despliegue de MFA
Genuino	4	Mide uso real si la instrumentación es correcta
Significativo	4	Cambios se interpretan fácilmente
Preciso	4	Datos transaccionales detallados
Oportuno	4	Medible en casi tiempo real
Independiente	3	Riesgo de inflar el % si se reclasifican transacciones como “no críticas”
Rentable	4	Aprovecha datos de sistemas IAM/APIs

2. Integridad

Indicador I1 – N° de incidentes de alteración de datos críticos detectados por año

Criterio	Score	Comentario breve
Predictivo	3	Describe histórico, tendencia alerta sobre debilidades
Relevante	5	Afecta decisiones, resultados clínicos, registros financieros
Accionable	4	Muestra dónde reforzar controles de integridad
Genuino	3	Depende de capacidad de detección; los no detectados no aparecen
Significativo	4	Picos o caídas son fáciles de interpretar
Preciso	3	Clasificación de “dato crítico” puede variar
Oportuno	4	Registro casi inmediato, agregación periódica
Independiente	3	Puede infra-reportarse si se percibe como fallo interno
Rentable	4	Usa registros de incidentes y auditoría

Indicador I2 – Tiempo medio de detección (MTTD) y corrección (MTTR) de alteraciones de integridad

Criterio	Score	Comentario breve
Predictivo	4	MTTD/MTTR altos anticipan mayor impacto en futuros incidentes
Relevante	4	Directamente vinculado a resiliencia de datos
Accionable	5	Señala procesos y herramientas a optimizar
Genuino	4	Mide tiempos reales si la cronología se registra bien
Significativo	4	Variaciones suelen ser significativas
Preciso	3	Requiere rigor en marcas temporales
Oportuno	4	Actualizable por incidente y por periodo
Independiente	4	Difícil de manipular sin alterar registros técnicos
Rentable	4	Se apoya en datos de tickets, SIEM, sistemas de cambio

Indicador I3 – Pérdida anual esperada por fallos de integridad (FAIR)

(Tabla análoga a A2: muy alta en Predictivo/Relevante/Accionable/Significativo, media en Preciso/Oportuno/Rentable.)

3. No repudio

Indicador NR1 – % de procesos críticos cubiertos por mecanismos fuertes de no repudio

Criterio	Score	Comentario breve
Predictivo	3	Cobertura alta reduce probabilidad de pérdidas futuras
Relevante	4	Vinculado a litigios, fraudes, sanciones
Accionable	5	Indica qué procesos requieren refuerzo (firmas, registros, etc.)
Genuino	4	Depende de un catálogo claro de procesos críticos
Significativo	4	Cambios en el % son interpretables
Preciso	3	Matiz en qué se considera “mecanismo fuerte”
Oportuno	3	Actualización menos frecuente (cuando cambian procesos)
Independiente	4	Poca tentación de manipulación directa
Rentable	4	Derivable de inventarios de procesos y controles

Indicador NR2 – N° y coste de disputas/litigios asociados a falta de evidencia suficiente

(Evaluado como: medio-alto en Predictivo/Relevante/Accionable/Significativo; algo menor en Preciso/Oportuno, por baja frecuencia.)

4. Confidencialidad

Indicador C1 – N° de incidentes de brecha de datos personales/sensibles (clasificados por severidad)

Indicador C2 – Pérdida anual esperada por brechas de confidencialidad (FAIR, incluyendo multas y reputación)

Indicador C3 – % de datos altamente sensibles cifrados en reposo y en tránsito

(Cada uno evaluado con la lógica ya mostrada: C2 sobresale en Predictivo/Relevante/Accionable; C3 es muy accionable y oportuno; C1 describe histórico y apoya regulación.)

5. Disponibilidad

Indicador D1 – Horas de indisponibilidad de servicios críticos por causas cibernéticas (anual)

Indicador D2 – Pérdida anual esperada por interrupciones (FAIR)

Indicador D3 – Cumplimiento de RTO/RPO para sistemas esenciales (% de éxito en pruebas y en incidentes reales)

(D2 sobresale en Predictivo/Relevante/Accionable; D1 y D3 son muy operativos y accionables.)

6. Autorización / privilegios

Indicador AU1 – N° de incidentes confirmados de abuso de privilegios (internos/externos)

Indicador AU2 – Cobertura de cuentas privilegiadas por solución PAM (%)

Indicador AU3 – Pérdida anual esperada por abusos de privilegios (FAIR)

(AU2 muy accionable y oportuno; AU3 muy fuerte en dimensión económica; AU1 describe realidad de amenaza interna.)

7. Síntesis comparativa

A nivel nacional, se recomienda:

- Priorizar métricas de pérdida anual esperada FAIR para cada dimensión (A2, I3, NR?, C2, D2, AU3) como indicadores macro de riesgo.
- Complementarlas con métricas operativas accionables (MFA, cifrado, PAM, RTO/RPO, cobertura de no repudio) para dirigir políticas y ayudas.
- Usar la matriz PRAGMATIC para ir retirando métricas decorativas y consolidar un set manejable pero robusto.

Cada país, sector u organización puede ajustar las puntuaciones PRAGMATIC, pero el esquema proporciona una base común para discutir la calidad de los indicadores, no sólo su existencia.